

Sept phrases à contredire

Votre expérience du terrain contre mes conclusions sur papier

Kélian Kaddouri

Ce qu'on vous demande, et surtout ce qu'on ne vous demande pas. *Pas* de lire mon mémoire. Je vous soumetts sept phrases sur lesquelles ce que vous avez vu chez des clients vaut mieux que n'importe quel calcul, et je vous demande d'essayer de les **contredire**. Un désaccord argumenté m'est plus utile qu'un accord, et il sera cité comme tel. Comptez une demi-heure.

De quoi il s'agit, en trois phrases. Je cherche à chiffrer ce que coûte, en capital réglementaire, le fait de mal appliquer le règlement européen sur la résilience informatique des acteurs financiers. Mon modèle suppose qu'un problème sur un domaine *entraîne* un autre, dans un certain ordre, plutôt que les problèmes ne surviennent chacun de leur côté. Cet ordre, je n'ai pas pu le mesurer sur des bases de données : je l'ai déduit de rapports d'enquête publics, et c'est exactement là que votre avis compte.

Les cinq domaines dont je parle. **Gouvernance** : qui décide, qui est responsable, quels moyens la direction met sur la sécurité. **Incidents** : repérer un incident, l'escalader, y répondre, le déclarer. **Tests** : tester avant de mettre en service, vérifier, appliquer les correctifs. **Prestataires** : les fournisseurs et la dépendance à un service extérieur. **Partage d'infos** : recevoir et faire circuler les alertes sur les menaces.

À lire avant de répondre aux phrases 3 et 4. Ces deux-là portent sur l'ordre dans lequel les choses lâchent, et je les ai déduites de rapports d'enquête officiels. Or une enquête officielle cherche toujours un responsable, et finit très souvent par conclure que la direction n'encadrerait pas assez. Il se peut donc que l'ordre que j'ai trouvé reflète la façon dont ces rapports sont écrits, plutôt que ce qui se passe vraiment dans une entreprise. **Votre réponse à ces deux phrases, fondée sur ce que vous avez vu et non sur des rapports, est le seul moyen de faire la différence.** Si vous manquez de temps, répondez à celles-là.

Les sept phrases

1. Ces cinq domaines suffisent à décrire la solidité informatique d'un acteur financier. Il n'en manque pas un, et ils ne se chevauchent pas au point de gêner.
2. Quand plusieurs domaines flanchent chez un même acteur, c'est souvent parce que l'un a entraîné l'autre, et pas seulement parce qu'une cause extérieure commune les a touchés tous les deux.
3. Une gouvernance défaillante dégrade les autres domaines, mais l'inverse ne se produit pas : un incident, un test raté ou un prestataire qui tombe ne dégradent pas la gouvernance elle-même. (*La phrase que j'aimerais le plus vous voir contredire. Avez-vous déjà vu un incident faire empirer la gouvernance ?*)
4. Les problèmes des autres domaines finissent par se voir dans la gestion des incidents, mais une mauvaise gestion des incidents ne dégrade pas en retour les tests, les prestataires ou la circulation de l'information.
5. Un prestataire partagé qui tombe abîme plusieurs domaines *en même temps*, au lieu de faire tomber les choses les unes après les autres. C'est différent des autres domaines, et je le traite différemment.
6. Ces trois indicateurs sont ceux qu'une direction des risques suit vraiment, ou pourrait produire sans grand chantier : le délai pour déclarer un incident, le temps qu'il faut pour le circonscrire, et le degré de concentration des prestataires.
7. Il serait réaliste de demander aux acteurs financiers un registre d'incidents qui note la date où l'incident *a eu lieu* (et non celle où il a été déclaré), qui range chaque incident par domaine plutôt que par type d'attaque, et qui compte un problème touchant vingt acteurs comme *un* événement à vingt victimes.

Votre réponse

Pour chaque phrase : **D** d'accord • **N** d'accord mais avec une nuance • **C** pas d'accord • **S** sans avis. Le commentaire est la partie qui m'intéresse vraiment : un exemple précis vaut mieux qu'une appréciation générale.

	D	N	C	S	Commentaire, exemple vécu
1					
2					
3					
4					
5					
6					
7					

La question la plus précieuse, pour finir. Qu'est-ce qui manque ? Quelle phrase aurait dû figurer dans cette liste, ou quel enchaînement voyez-vous régulièrement sur le terrain et dont je ne parle nulle part ?

Ce que je ferai de vos réponses. Elles seront citées dans mon mémoire, et les désaccords en premier. Si vous contredisez la phrase 3 ou la 4, je corrige le modèle : c'est précisément pour cela que je vous écris. Merci de me dire votre rôle, votre secteur, depuis combien de temps vous exercez, et si vous acceptez d'être cité par votre nom ou préférez rester anonyme.

Merci du temps que vous y passerez. Kélian Kaddouri • kkaddouri@nexialog.com